QUANTUM SECURITY INTELLIGENCE

Отчёт об аудите безопасности и постквантовой готовности

pasta-curves @ e3c0f0246f56 · Electric Coin Company (Zcash) — публичный репозиторий (пассивная проверка)

Организация	QSI
Дата отчёта	2026-10-30 20:59 UTC
Версия отчёта	1
Запуск аудита	ebc4cacf-0b49-4605-b458-daffef75c78e · Документальный аудит · 2026-10-30 20:59 UTC
Версия анализатора	qsi-engine 1.2.0
Профиль риска	Криптобиржа, кастодиан или кошелёк
SHA-256 содержимого	`2919c46477b0ece07cb139e575e93a0c5fa3adc70e68306085e2b990adc39eba`
Ключ подписи (Ed25519, отпечаток SHA-256; подпись — отдельный файл report.sig.json)	`5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`

Содержание

1. Резюме для руководства
2. Область и границы проверки
3. Методология
4. Проверенные и непроверенные активы
5. Краткое описание архитектуры
6. Общая оценка состояния безопасности
7. Сводка находок по серьёзности
8. Подробное описание находок
9. Подтверждающие доказательства
10. Постквантовая оценка
11. Ограничения и допущения
12. План устранения проблем
13. Приоритеты на 30, 60 и 90 дней
14. Проверки после устранения
15. Использованные инструменты
16. Источники и нормативные документы
17. Приложения

Отчёт содержит результаты автоматизированного и документального анализа в указанных границах. Он не является юридическим заключением, сертификацией или подтверждением соответствия какому-либо стандарту.

Резюме для руководства

3	0	0	1	0
Всего находок	Критическая	Высокая	Средняя	Низкая

Классификация	Количество
Подтверждённая техническая уязвимость	0
Известная уязвимая версия компонента	0
Подтверждённая ошибка конфигурации	0
Потенциальный криптографический риск	0
Долгосрочный постквантовый риск	1
Рекомендация по улучшению	1
Недостаточность данных	1

Top 5

ID	Серьёзность	Подробное описание находок	Балл приоритета
QSI-2026-07555	Средняя	Квантово-уязвимый Pasta curves (Pallas/Vesta): роль не определена (4 файл(ов)) предварительно	34.2
QSI-2026-07557	Информационная	3 бюллетеней в 2 пакет(ах) crates.io, нужных только для разработки или сборки предварительно	15.5
QSI-2026-07556	Информационная	Не обнаружено криптобиблиотек с поддержкой PQC предварительно	13.3

Неравенство Моски (x + y > z): x = 10, y = 5, z = 8 → при этом сценарии миграция завершится слишком поздно. z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.

Постквантовая зрелость: Уровень 0 из 4 — постквантовой криптографии нет. Следующий шаг: Проведите инвентаризацию: где классическая криптография с открытым ключом защищает долгоживущие данные и ключи, и выберите первую миграцию — обычно гибридный обмен ключами TLS и обёрнутые ключи.

Область и границы проверки

Режим: Документальный аудит

Репозиторий: https://github.com/zcash/pasta_curves @ e3c0f0246f56d351f1a94ff0a74c8d201dbf87d9 — ссылки в доказательствах открывают строки на этом коммите.

Предоставленные входные данные

35 файлов, всего 771112 байт, редактирований: 0; список SHA-256 по файлам — в приложении C.

Методология

Аудит выполнен движком QSI 1.2.0. Каждый анализатор формирует факты (правило, параметры, доказательства); тексты находок генерируются из каталога правил. Источники методики указаны в разделе «Источники и нормативные документы».

Приоритизация: объяснимая взвешенная модель (серьёзность, вероятность эксплуатации, доступность атакующему, влияние на конфиденциальность/целостность/доступность с весами профиля «Криптобиржа, кастодиан или кошелёк», критичность актива, срочность, простота устранения) с множителем уверенности. CVSS v3.1 применяется только к техническим уязвимостям с определённым вектором. Для долгосрочных квантовых рисков используется неравенство Моски; их серьёзность ограничена уровнем «Средняя», и они никогда не представляются как эксплуатируемые уязвимости.

Классификация находок: подтверждённая техническая уязвимость; известная уязвимая версия компонента (версия зависимости названа в бюллетене; затронутый код может не вызываться — это проверяется отдельно, а подтверждённая проверкой становится уязвимостью); подтверждённая ошибка конфигурации; потенциальный криптографический риск; долгосрочный постквантовый риск; рекомендация по улучшению; недостаточность данных. Находки на основе эвристик помечены как предварительные; решения аналитика показаны рядом с находками.

Покрытие проверок

Область	Статус	Количество	Примеры
dependencies	проверено	3	Cargo.lock: 111 dependencies parsed (111 pinned); Cargo.toml: 17 dependencies parsed (0 pinned); sage/pyproject.toml: 2 dependencies parsed (0 pinned)
source_code	проверено	31	lean/scripts/asm_source.py: 800 lines scanned with 16 rule patterns and 130 registry patterns; lean/scripts/check_export_axioms.py: 516 lines scanned with 16 rule patterns and 130 registry patterns; lean/scripts/check_export_coverage.py: 54 lines scanned with 16 rule patterns and 130 registry patterns
tls_key_exchange_groups	Недостаточность данных	1	lean/scripts/gen_aarch64.py line 767: not in the algorithm registry, not assessed: []
tls_configuration	проверено	1	lean/scripts/gen_aarch64.py: openssl TLS directives parsed
osv_advisories	проверено	1	111 pinned packages queried at OSV.dev; 2 affected (2 of them only in development or build dependencies)

Длинные списки здесь сгруппированы; полный список по файлам — в JSON-версии отчёта, подписанной тем же ключом.

Проверенные и непроверенные активы

Предоставленные входные данные: 35 (входные файлы: C)

Не проверено

- tls_key_exchange_groups: lean/scripts/gen_aarch64.py line 767: not in the algorithm registry, not assessed: []

Краткое описание архитектуры

Static review of the source tree pasta-curves at e3c0f0246f56d351f1a94ff0a74c8d201dbf87d9. 35 files analysed; of 180 files, 38 are test, fuzzing, benchmark or example code and were left out, 107 are not read by any analyzer, 0 exceed the per-file limit and 0 did not fit the total limit. Files no analyzer reads include: .gitattributes, .github/ISSUE_TEMPLATE/eli15.md, .github/dependabot.yml, .github/workflows/asm.yml, .github/workflows/book.yml. 29 files in build-output or dependency-cache directories (.git, .hg, .venv, __pycache__, build, dist, node_modules, target, vendor, venv) were not read. No requests were sent to the owner's systems.

Общая оценка состояния безопасности

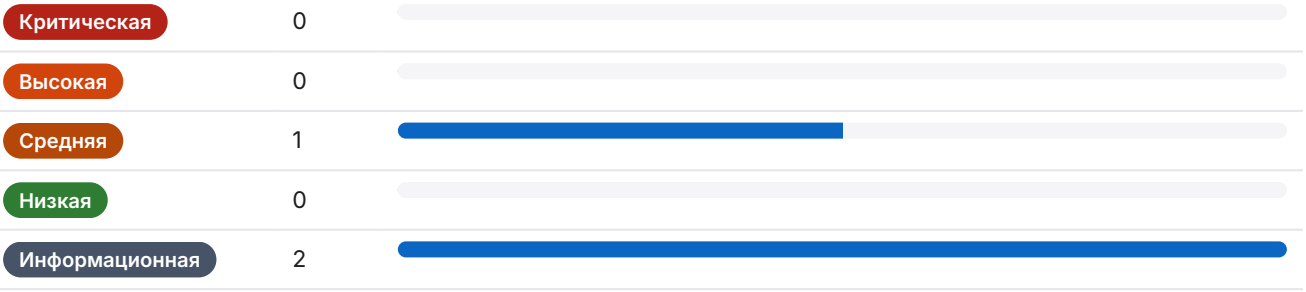
100
Ориентировочный индекс состояния (0–100)

55.6%
Доля квантово-уязвимых элементов инвентаризации

9
Криптографическая инвентаризация

Рассчитан по находкам в области проверки (подтверждённые и потенциальные проблемы, взвешенные по серьёзности). Ориентировочный; не сравним между аудитами с разной областью.

Сводка находок по серьёзности



ID	Подробное описание находок	Классификация	Серьёзность	Уверенность
QSI-2026-07555	Квантово-уязвимый Pasta curves (Pallas/Vesta): роль не определена (4 файл(ов))	Долгосрочный постквантовый риск	Средняя	Средняя, предварительно
QSI-2026-07557	3 бюллетеней в 2 пакет(ах) crates.io, нужных только для разработки или сборки	Рекомендация по улучшению	Информационная	Средняя, предварительно
QSI-2026-07556	Не обнаружено криптобиблиотек с поддержкой PQC	Недостаточность данных	Информационная	Средняя, предварительно

Подробное описание находок

QSI-2026-07555 · CODE-QV-ASYMMETRIC

Средняя

Квантово-уязвимый Pasta curves (Pallas/Vesta): роль не определена (4 файл(ов))

Долгосрочный постквантовый риск | Уверенность: Средняя | предварительно — требует дополнительной проверки

21 упоминаний Pasta curves (Pallas/Vesta) в 4 файл(ах), например src/curves.rs:1066. Роль по путям, именам функций и соседнему коду: роль не определена. По коду не видно, что защищают ключи; приоритет определит проверка.

Затронутый актив	source-code:Pasta curves (Pallas/Vesta):general
Источник данных	src/curves.rs
Метод обнаружения	Сопоставление регулярных выражений с криптографическими API; роль определяется по словам в путях, именам охватывающих функций и строкам рядом с совпадениями.
Анализатор	source_code 1.2.0 · 2026-10-30 20:59 UTC
Балл приоритета	34.2 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо
Неравенство Моски (x + y > z)	x=10.0, y=5.0, z=8.0 → при этом сценарии миграция завершится слишком поздно

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Долгосрочный риск зависит от назначения: подписи (подлинность до миграции) или обмен ключами/шифрование (ретроспективная расшифровка записанных данных).

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
Откройте src/curves.rs:1066 и проверьте приведённые строки; остальные файлы перечислены в доказательствах.
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

file_excerpt · src/curves.rs · line 1066 · SHA-256 83fde1e70d213628… · Файл 91d74885713c0303…

```
1065 |
1066 | new_curve_impl!(
1067 |     (pub),
```

file_excerpt · src/curves.rs · line 1070 · SHA-256 253bef6339b63f0b… · Файл 91d74885713c0303…

```
1069 |     EpAffine,
1070 |     IsoEp,
1071 |     Fp,
```

file_excerpt · src/curves.rs · line 1080 · SHA-256 5cd0058ebbc73509… · Файл 91d74885713c0303…

```
1079 | );
1080 | new_curve_impl!(
1081 |     (pub),
```

file_excerpt · src/lib.rs · line 45 · SHA-256 d613a2d1a40df0ee… · Файл bf59271f6794fa7f…

```
   44 | pub mod deferred;
   45 | pub mod pallas;
   46 | pub mod vesta;
```

file_excerpt · src/lib.rs · line 46 · SHA-256 8e4a619713e5ddc4… · Файл bf59271f6794fa7f…

```
   45 | pub mod pallas;
   46 | pub mod vesta;
   47 |
```

file_excerpt · src/pallas.rs · line 27 · SHA-256 574f80fe0cb9f247… · Файл b76caee73b607aab…

```
   26 |     // implement Shake128 any more but that's fine.
   27 |     let r = super::IsoEp::new_jacobian(
   28 |         Base::from_raw([
```

file_excerpt · src/pallas.rs · line 48 · SHA-256 219f417612949fbc… · Файл b76caee73b607aab…

```
   47 |     .unwrap();
   48 |     let p = super::hashtocurve::iso_map::<_, Point, super::IsoEp>(&r,
&Ep::ISOGENY_CONSTANTS);
   49 |     let (x, y, z) = p.jacobian_coordinates();
```

file_excerpt · src/pallas.rs · line 63 · SHA-256 ea70784da2cdf314… · Файл b76caee73b607aab…

```
   62 |     assert!(bool::from(r2.is_on_curve()));
   63 |     let p2 = super::hashtocurve::iso_map::<_, Point, super::IsoEp>(&r2,
&Ep::ISOGENY_CONSTANTS);
   64 |     assert!(bool::from(p2.is_on_curve()));
```

file_excerpt · src/vesta.rs · line 21 · SHA-256 bea22f200f9dd677… · Файл 76dab33aa7bc55ae…

```
   20 |     use crate::arithmetic::CurveExt;
   21 |     use crate::curves::IsoEq;
   22 |     use crate::hashtocurve::map_to_curve_simple_swu;
```

file_excerpt · src/vesta.rs · line 25 · SHA-256 177934d421270aec… · Файл 76dab33aa7bc55ae…

```
   24 |     // The zero input is a special case.
   25 |     let p: IsoEq = map_to_curve_simple_swu::<Fq, Eq, IsoEq>(&Fq::zero(), Eq::THETA, Eq::Z);
   26 |     let (x, y, z) = p.jacobian_coordinates();
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Это прогнозный риск, зависящий от появления криптографически значимого квантового компьютера (CRQC). Публично известных CRQC сегодня нет; сроки неопределённы. Это не уязвимость, эксплуатируемая сегодня. Эвристическое сопоставление шаблонов в исходном тексте без анализа потоков данных. Контекст использования (влияет ли на безопасность) требует ручного подтверждения; находка предварительная.

РЕКОМЕНДАЦИЯ

Классифицируйте каждое использование, зафиксируйте сроки жизни данных и запланируйте миграцию на постквантовый алгоритм; введите уровень абстракции для криптогибкости.

ПОВТОРНАЯ ПРОВЕРКА

Повторите инвентаризацию после рефакторинга.

P. W. Shor — Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer (SIAM J. Comput., 1997); NIST IR 8547 — Transition to Post-Quantum Cryptography Standards; M. Mosca — Cybersecurity in an Era with Quantum Computers: Will We Be Ready? (IEEE Security & Privacy, 2018)

QSI-2026-07557 · DEP-ADVISORY-DEV

Информационная

3 бюллетеней в 2 пакет(ах) crates.io, нужных только для разработки или сборки

Рекомендация по улучшению | Уверенность: Средняя | предварительно — требует дополнительной проверки

OSV.dev сообщает 3 бюллетеней (0 с оценкой high или critical) для 2 пакет(ов) crates.io, которые подтягивают только инструменты разработки или сборки (Cargo.lock): например, atty@0.2.14 [dev]: GHSA-g98v-hv3f-hcfr, RUSTSEC-2024-0375; bincode@1.3.3 [dev]: RUSTSEC-2025-0141. Манифесты помечают их так (devDependencies, "dev": true в package-lock.json, [dev-dependencies]/[build-dependencies] через граф Cargo.lock), поэтому в поставляемый продукт они не входят.

Затронутый актив	dependencies:crates.io:non-runtime
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch по точным версиям; область применения — из devDependencies, флагов dev в package-lock.json, разделов importers в pnpm, графа Cargo.lock от таблиц Cargo.toml и — для yarn.lock, который область не записывает вовсе — графа файла блокировки, пройденного от package.json. Если рабочее требование в файле блокировки разрешить не удалось, файл остаётся без классификации, чтобы пакет не был отложен в сторону по ошибке.
Анализатор	dependencies 1.2.0 · 2026-10-30 20:59 UTC
Балл приоритета	15.5 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Пользователей продукта они не затрагивают. Они могут влиять на машины разработчиков и CI (цепочка поставки): скомпрометированный или уязвимый инструмент способен изменить сборку.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
Найдите пакеты из доказательства на https://osv.dev и проверьте их область применения в Cargo.lock.
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev (crates.io) · Cargo.lock · SHA-256 a929489dbe602baa...

```
atty@0.2.14 [dev]: GHSA-g98v-hv3f-hcfr, RUSTSEC-2024-0375
bincode@1.3.3 [dev]: RUSTSEC-2025-0141
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные получены от OSV.dev в зафиксированное время. Области применения взяты из манифестов; собственные build-зависимости крейтов реестра в Cargo.lock не различимы, поэтому множество runtime может оказаться больше реального, но не меньше.

РЕКОМЕНДАЦИЯ

Обновите инструменты в рамках планового обслуживания; в первую очередь пакеты, которые выполняются в CI с секретами или создают релизные артефакты.

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV.dev — open-source vulnerability database and API

QSI-2026-07556 · DEP-NO-PQC-LIBRARY

Информационная

Не обнаружено криптобиблиотек с поддержкой PQC

Недостаточность данных | Уверенность: Средняя | предварительно — требует дополнительной проверки

В 3 манифестах зависимостей QSI нашёл криптобиблиотеки (ff, group), но ни одной из списка поддерживающих PQC.

Затронутый актив	dependencies
Источник данных	dependency manifests
Метод обнаружения	Сопоставление названий зависимостей.
Анализатор	dependencies 1.2.0 · 2026-10-30 20:59 UTC
Балл приоритета	13.3 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Только индикатор готовности: поддержка PQC может обеспечиваться платформой (OpenSSL, ОС, облачный KMS), а не зависимостями приложения.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
Изучите перечисленные в доказательстве манифесты.
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

dependency · Cargo.lock, Cargo.toml, sage/pyproject.toml · SHA-256 8394c464da802a31…

```
Crypto libraries: ff, group
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Отсутствие доказательств не является доказательством отсутствия: системные библиотеки и транзитивные зависимости могут не указываться.

РЕКОМЕНДАЦИЯ

Определите источник поддержки PQC (TLS-терминатор, KMS/HSM, обновление библиотек).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование после обновлений.

FIPS 203 — Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM); FIPS 204 — Module-Lattice-Based Digital Signature Standard (ML-DSA)

Подтверждающие доказательства

ID	Тип	Источник данных	SHA-256
QSI-2026-07555	file_excerpt	src/curves.rs (line 1066)	83fde1e70d213628f3c9976ebe67c2fc74436f36ef46ec926e4a9a6d8c655713
QSI-2026-07555	file_excerpt	src/curves.rs (line 1070)	253bef6339b63f0bb960716cecb41d520c6abeaf222cd184554270b0b2b32254
QSI-2026-07555	file_excerpt	src/curves.rs (line 1080)	5cd0058ebbc73509bd9582c2a6387318e3915238dafa8a023b6305bc4534afb5
QSI-2026-07555	file_excerpt	src/lib.rs (line 45)	d613a2d1a40df0eefae7099af56302a158e0b43c5aaee481a42a9a5ae4969f68
QSI-2026-07555	file_excerpt	src/lib.rs (line 46)	8e4a619713e5ddc491f9bf374652eaf2bd71bdb26e86c1080c230108f94ae670
QSI-2026-07555	file_excerpt	src/pallas.rs (line 27)	574f80fe0cb9f247fda677dce82366e1f115a07dde50d6e1251558bcde6a769f
QSI-2026-07555	file_excerpt	src/pallas.rs (line 48)	219f417612949fbca47e488784fe57ec076287462f01e56410b5316be29e1ad2
QSI-2026-07555	file_excerpt	src/pallas.rs (line 63)	ea70784da2cdf3146cf852d890a5d602b3f61f9968c725d74d46e929ff137966
QSI-2026-07555	file_excerpt	src/vesta.rs (line 21)	bea22f200f9dd677668e3ace45534bf3c4dcba72ef012b13f32e79a555a8c70f
QSI-2026-07555	file_excerpt	src/vesta.rs (line 25)	177934d421270aecd9abe365658eb2b9f729d8eb4998339b2dee10bdc7fd1a38
QSI-2026-07557	tool_output	OSV.dev (crates.io) (Cargo.lock)	a929489dbe602baa22761100a6619ac454c7430823f7fe7c7e96022bb2fefb48
QSI-2026-07556	dependency	Cargo.lock, Cargo.toml, sage/ pyproject.toml	8394c464da802a3186151760bcefdd3dd06a8ad0e233375abbe28269a50aa4c6

Постквантовая оценка

	Обмен ключами (x — сколько данные должны оставаться конфиденциальными; «собери сейчас, расшифруй потом»)	Подписи (x — сколько подписи и ключи должны оставаться доверенными)
Срок жизни данных/ключей x	10	10
Время миграции y	5	5
Принятое число лет до CRQC z	8 (early)	8
x + y − z	7 → при этом сценарии миграция завершится слишком поздно	7 → при этом сценарии миграция завершится слишком поздно

Допущения планирования: x для обмена ключами, x для подписей, y — значения по умолчанию профиля риска «Криптобиржа, кастодиан или кошелёк», а не данные клиента; с фактическими сроками клиента вывод может измениться.

Постквантовая зрелость: Уровень 0 из 4 — постквантовой криптографии нет

Следующий шаг: Проведите инвентаризацию: где классическая криптография с открытым ключом защищает долгоживущие данные и ключи, и выберите первую миграцию — обычно гибридный обмен ключами TLS и обёрнутые ключи.

Уровни: 0 — нет; 1 — есть, но не подключено; 2 — используется вне критичных путей; 3 — гибрид в критичном пути; 4 — постквантовое по умолчанию в критичных путях (корень доверия, обёртка ключей, обмен ключами в канале). Оценка по коду и манифестам.

Что делают квантово-уязвимые алгоритмы

Роль	Алгоритмы (файлы)	ID	Первый шаг
роль не определена	Pasta curves (Pallas/Vesta) (4)	QSI-2026-07555	Классифицируйте каждое использование, зафиксируйте сроки жизни данных и запланируйте миграцию на постквантовый алгоритм; введите уровень абстракции для криптогибкости

Роль определяется по путям файлов, именам функций и коду вокруг совпадений; проверка её подтверждает. Сначала — ключи корня доверия и обёрнутые ключи: их трудно заменить или можно записать уже сегодня.

z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.

Квантовый статус	Количество

н/п	4
уязвим (Шор)	5

Подробное описание находок: QSI-2026-07555

Анкета постквантовой готовности

Анкета готовности для проекта не заполнялась.

Квантовые алгоритмы, значимые для этой инвентаризации

Квантовый алгоритм	Действие	Алгоритмы из инвентаризации (строк)	Что это значит для аудита
Алгоритм Шора — дискретный логарифм на эллиптических кривых Q1: квантовые вычисления офлайн, классический доступ к жертве	взламывает	Pasta curves (Pallas/Vesta) (5)	Ключи на эллиптических кривых, по оценкам, падут раньше ключей RSA сопоставимой классической стойкости. В блокчейнах первыми под угрозой монеты, чей открытый ключ уже опубликован (повторно используемые адреса, выходы pay-to-public-key и Taproot); планируйте переход на постквантовые подписи и до этого избегайте повторного использования ключей.

Действие: взламывает — алгоритм нужно заменить; ослабляет — более длинные ключи или выходы восстанавливают запас; учтено в стандартных параметрах — при стандартных наборах действий не требуется; только при суперпозиционных запросах — к обычному применению неприменимо.

Ограничения и допущения

- Отчёт содержит результаты автоматизированного и документального анализа в указанных границах. Он не является юридическим заключением, сертификацией или подтверждением соответствия какому-либо стандарту.
- z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.
- tls_key_exchange_groups — Недостаточность данных: lean/scripts/gen_aarch64.py line 767: not in the algorithm registry, not assessed: []

План устранения проблем

QSI-2026-07555 · P3 · 90 дн. краткосрочное снижение риска

Внесите использования Pasta curves (Pallas/Vesta) в source code в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).

Обоснование	Без понимания, где и зачем используется алгоритм, миграцию невозможно спланировать.
Ожидаемый результат	У каждого использования есть владелец, срок жизни и путь миграции.
Сложность	medium
Зависимости	Доступ к владельцам систем.
Побочные эффекты	Нет (документация и проектирование).
Тесты до изменения	Подтвердите соответствие записи развёрнутой конфигурации.
Тесты после изменения	Инвентаризация согласована владельцем системы.
Условие закрытия	Существует запись инвентаризации с владельцем, сроком жизни и целевым алгоритмом.

QSI-2026-07555 · P4 · 90 дн. устранение первопричины

Запланируйте миграцию Pasta curves (Pallas/Vesta) на (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.

Обоснование	Устраняет зависимость от квантово-уязвимого примитива с открытым ключом.
Ожидаемый результат	Актив использует стандартизированный NIST постквантовый или гибридный алгоритм.
Сложность	high
Зависимости	Поддержка в библиотеках/протоколах (например, OpenSSL ≥ 3.5, прошивки HSM), совместимость с контрагентами.
Побочные эффекты	Больший размер ключей/подписей, возможное влияние на производительность и совместимость.
Тесты до изменения	Тесты совместимости на стенде.
Тесты после изменения	Проверьте фактически используемый алгоритм на рабочем активе.
Условие закрытия	Повторный аудит показывает использование или гибридной схемы.

QSI-2026-07557 · P4 · 90 дн. устранение первопричины

Обновите зависимости разработки и сборки из доказательства.

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Обновление инструментов может изменить результат сборки; сравните релизные артефакты.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.

Условие закрытия	Сканирование не сообщает бюллетеней для пакетов инструментов, либо оставшиеся зафиксированы.

Приоритеты на 30, 60 и 90 дней

30 дн.

Приоритет	ID	Действие	Тип
Нет			

60 дн.

Приоритет	ID	Действие	Тип
Нет			

90 дн.

Приоритет	ID	Действие	Тип
P3	QSI-2026-07555	Внесите использования Pasta curves (Pallas/Vesta) в source code в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).	краткосрочное снижение риска
P4	QSI-2026-07555	Запланируйте миграцию Pasta curves (Pallas/Vesta) на (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.	устранение первопричины
P4	QSI-2026-07557	Обновите зависимости разработки и сборки из доказательства.	устранение первопричины

Проверки после устранения

ID	Повторная проверка
QSI-2026-07555	Повторите инвентаризацию после рефакторинга.
QSI-2026-07557	Повторите сканирование зависимостей после обновления.
QSI-2026-07556	Повторите сканирование после обновлений.

Использованные инструменты

Tool	Version
blockchain	1.0.0
certificates	1.1.0
chain_map	1.0.0
configs	1.1.0
dependencies	1.2.0
inventory_document	1.1.0
solidity	1.2.0
source_code	1.3.0
tls_code	1.1.0
tls_live	1.0.0
qsi-engine	1.2.0
OSV.dev API	v1

Источники и нормативные документы

Reviewed: 2026-10-13

1. C. Chevignard, P.-A. Fouque, A. Schrottenloher — Reducing the Number of Qubits in Quantum Discrete Logarithms on Elliptic Curves (IACR ePrint 2026/280) — IACR ePrint. https://eprint.iacr.org/2026/280 (revision of a EUROCRYPT 2026 paper: 3.12n + o(n) qubits; for n = 256, 1193 qubits and 22 runs of 2^38.98 Toffoli gates)
2. Common Vulnerability Scoring System v3.1: Specification Document — FIRST. https://www.first.org/cvss/v3.1/specification-document (final)
3. D. Litinski — How to compute a 256-bit elliptic curve private key with only 50 million Toffoli gates (arXiv:2306.08585) — arXiv. https://arxiv.org/abs/2306.08585 (preprint (2023-06-14): 6000 modules × 1152 physical qubits, one key per 10 minutes under its architecture assumptions)
4. FIPS 203 — Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM) — NIST. https://csrc.nist.gov/pubs/fips/203/final (final (August 2024))
5. FIPS 204 — Module-Lattice-Based Digital Signature Standard (ML-DSA) — NIST. https://csrc.nist.gov/pubs/fips/204/final (final (August 2024))
6. FIPS 205 — Stateless Hash-Based Digital Signature Standard (SLH-DSA) — NIST. https://csrc.nist.gov/pubs/fips/205/final (final (August 2024))
7. J. Proos, C. Zalka — Shor's discrete logarithm quantum algorithm for elliptic curves (Quantum Inf. Comput. 3(4), 2003; arXiv:quant-ph/0301141) — Quantum Information & Computation. https://doi.org/10.26421/QIC3.4-3 (peer-reviewed article)
8. M. Cain et al. — Shor's algorithm is possible with as few as 10,000 reconfigurable atomic qubits (arXiv:2603.28627) — arXiv. https://arxiv.org/abs/2603.28627 (preprint (2026-03-30): P-256 in a few days with 26,000 physical neutral-atom qubits; RSA-2048 one to two orders of magnitude longer)
9. M. Mosca — Cybersecurity in an Era with Quantum Computers: Will We Be Ready? (IEEE Security & Privacy, 2018) — IEEE. https://doi.org/10.1109/MSP.2018.3761723 (peer-reviewed article; source of the x + y > z migration inequality)
10. M. Roetteler, M. Naehrig, K. Svore, K. Lauter — Quantum resource estimates for computing elliptic curve discrete logarithms (ASIACRYPT 2017) — IACR / arXiv. https://arxiv.org/abs/1706.06752 (peer-reviewed article: at most 9n + 2⌈log2 n⌉ + 10 qubits and 448 n^3 log2 n + 4090 n^3 Toffoli gates)
11. NIST IR 8547 — Transition to Post-Quantum Cryptography Standards — NIST. https://csrc.nist.gov/pubs/ir/8547/ipd (initial public draft (November 2024); proposes deprecating quantum-vulnerable public-key algorithms after 2030 and disallowing them after 2035 — dates may change in the final version)
12. OSV.dev — open-source vulnerability database and API — Open Source Security Foundation. https://osv.dev/ (the database QSI queries for each exactly pinned version; every advisory id in a finding resolves at https://osv.dev/vulnerability/<id>)
13. P. W. Shor — Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer (SIAM J. Comput., 1997) — SIAM. https://doi.org/10.1137/S0097539795293172 (peer-reviewed article)
14. R. Babbush et al. — Securing Elliptic Curve Cryptocurrencies against Quantum Vulnerabilities: Resource Estimates and Mitigations (arXiv:2603.28846) — arXiv. https://arxiv.org/abs/2603.28846 (preprint (2026-03-30, v2 2026-04-15): 256-bit ECDLP with < 1200 logical qubits and < 90 M Toffoli gates (or < 1450 and < 70 M); < 500,000 physical qubits at 10^-3 error, minutes)

Приложения

A. Криптографическая инвентаризация

Алгоритм	Параметр	Расположение	Квантовый статус	Классический статус
Crypto library ff (jubjub)	0.14.0	Cargo.lock	н/п	допустимо
Crypto library group (jubjub)	0.14.0	Cargo.lock	н/п	допустимо
Crypto library ff (jubjub)	0.14	Cargo.toml	н/п	допустимо
Crypto library group (jubjub)	0.14	Cargo.toml	н/п	допустимо
Pasta curves (Pallas/Vesta)		src/curves.rs:1066	уязвим (Шор)	допустимо
Pasta curves (Pallas/Vesta)	Pallas	src/lib.rs:45	уязвим (Шор)	допустимо
Pasta curves (Pallas/Vesta)	Vesta	src/lib.rs:46	уязвим (Шор)	допустимо
Pasta curves (Pallas/Vesta)		src/pallas.rs:27	уязвим (Шор)	допустимо
Pasta curves (Pallas/Vesta)		src/vesta.rs:21	уязвим (Шор)	допустимо

B. JSON

qsi.report/1 · SHA-256 2919c46477b0ece07cb139e575e93a0c5fa3adc70e68306085e2b990adc39eba

C. Входные файлы

Файл	Размер	SHA-256	Маскирован
Cargo.lock	25638	`4f191ee7c7affbd7f07521144b7b270b024b8ee35b15d09da475f81b057a91a7`	0
Cargo.toml	2858	`0a6cc95e94695197e703e438a9c031a4cc3333cd4b17562f75337a52d00621dc`	0
lean/scripts/asm_source.py	32332	`3cf7d6b80731ea5106751bf6f85af948549058c5b4aa871e752b4cec6d889101`	0
lean/scripts/check_export_axioms.py	23429	`f00f566828797565e1cb14514db76b607552f507a0b833fcc80db948bc73c867`	0
lean/scripts/check_export_coverage.py	1877	`4e8e7984a90ceb8d67f7b08dda80d462664771bc353d7b0c2d0bfb1d36d848b4`	0
lean/scripts/gen.py	47849	`ebd255b8d63e7114b7ee373c3197b774b3df6d6f88e0e8d4c8923262788eb0ab`	0
lean/scripts/gen_aarch64.py	50971	`b2bf02c086e2861eccc5c476e6f545f5e33b85951c4b0a6e24472c2843d72d56`	0
lean/scripts/gen_hull.py	8333	`c024bdcc3e54fb4056b2fa261fa44fd077bfc3554284aeda20e1f0f6d1c439f9`	0
lean/scripts/gen_x86_64.py	43299	`f438270507fa060f98817bdba303722b84385fc33e0c93bbda97875153199340`	0

lean/scripts/verify_hull_certificate.py	15751	af5a5bc8c134cf841c0643196f2963ce04dc6cebcffdc12b76dc35452daccf3f	0
rust-toolchain.toml	68	0e85702dd92c5c86fbcb0b22e4331af26dd90d4cb8749227d143b067f3706276	0
sage/pyproject.toml	390	92c0ff03772029814b3402227905ca7f2dd13dd67b9050bfcccea6db8f1149be	0
src/arithmetic.rs	354	cd8e62310ca4253e9e65d06356829e23dac2586d20062c62ac2eab748dbb3297	0
src/arithmetic/curves.rs	11009	cdb939cc833d5869326194905778293581 4dc4ff69db3e35304b9b53e1c4841f	0
src/arithmetic/fields.rs	16708	45d7a8a77b6f6ebb9ad2d8b275752d913cf649272ed8353ba75fc958e61cd368	0
src/asm/aarch64.rs	61946	5c69fadf8594f173eec8c38c9c5e329bf0dc58de088768a4ac92fdec1c41b34f	0
src/asm/entry.rs	9979	a5a1df9c77f976406641317a14799d54406a72f751db2a8cde8b74293a623a1c	0
src/asm/mod.rs	6527	21a051ece5eedac74de9c074946ac2007a10e521d050d8f082663ee25668b582	0
src/asm/x86_64.rs	36656	e9ffdf5638b187f53cf5a7ac909117933e7444697c3e86755ceb301535c8a3f6	0
src/curves.rs	48594	91d74885713c0303372309c40ba46671dddf2399c0daf587f16b476eeb3364b8	0
src/deferred.rs	10710	d1b1a6707e446618d3bedb1b2b74e15f8f669e58b0b44c79fe3484cb21f081e0	0
src/fields.rs	1113	a2df1a34bfb6ea442317639f8a9dbc081aff86de7de83b5d851bfb18ac99ef44	0
src/fields/fp.rs	48780	22e857ffb73dd92dbaf60fc0f618c3c663580b5f0cb3b681c7446fb1cba5db2b	0
src/fields/fq.rs	48429	1a713f5e9d3b4d39edbe2fbc3e25d3ca63047f27592f62e20f29e4c19ab15408	0
src/fields/modinv62.rs	71527	ca55e6944a2437d0d7fd5f6ea8f2de320455774ad99b59e1c88ea62c27794308	0
src/glv.rs	36917	a18beefb7c9b222772fa456d5fbb7d52c16c33894db27655293bae455d127eb4	0
src/hashtocurve.rs	10528	1dcda56f13b037ef170a043b576932b40cc1a6dc0415d0c79682b145b7694196	0
src/inversion.rs	54489	d0fbb178a40f98c91e6097a08f0a28227e2ffce1d02343c24e3a4e58c47c2873	0
src/inversion/portable.rs	13092	4a81b25e4998791aedd5950b9e0a59bedd5e37d2b82c700cbec26ba722d0d739	0
src/lib.rs	3474	bf59271f6794fa7fad77adc3921e296f56cda92f57dbe6106647d72d56be4eb4	0
src/limbs.rs	2508	7d41fc79396b8e292d073ab33fb29c30662ceea42dab757e0f54f234d92be4a9	0
src/macros.rs	4230	9292c7aff80448b3149934c28da525d477b7acdc2d4d2623c75c110e7dcd922f	0
src/pallas.rs	5320	b76caee73b607aab5045b3911c83b86f3e78ae41dbe8c86be3dbe3245b8caf6d	0
src/serde_impl.rs	13003	63eb918536ee8df39f7f1ce21ed85118193735900f9b85ad305fc799138fba3b	0
src/vesta.rs	2424	76dab33aa7bc55ae409c5711cc263e1fd46726575922ca636c41a35779364bde	0